



CYBERSICUREZZA AZIENDALE

GUIDA PER PROFESSIONISTI IT



AGENZIA PER
LA CYBERSICUREZZA
NAZIONALE

Le iniziative di promozione della cybersicurezza aziendale sono fondamentali per essere consapevoli del ruolo chiave che la cybersicurezza riveste nella transizione digitale.

Molte realtà aziendali non hanno ancora intrapreso un percorso adeguato per proteggere i propri processi, oppure hanno adottato soluzioni solo parziali. Questa situazione è spesso causata dalla mancanza di una pianificazione strutturata e, soprattutto, alla scarsa priorità assegnata alle misure volte a potenziare la capacità di prevenzione, monitoraggio e contrasto delle minacce informatiche, in relazione al livello di esposizione ai rischi.

4,5 milioni
di PMI
sempre più a rischio di
attacchi
informatici

Le piccole e medie imprese (PMI) Italiane (circa 4,5 milioni di imprese¹) rappresentano un asse portante del motore economico del Paese. Molte di esse operano nelle filiere di operatori pubblici e privati che gestiscono infrastrutture critiche nazionali. Le analisi condotte dal Computer Security Incident Response Team (CSIRT Italia) dell'Agenzia per la Cybersicurezza Nazionale, insieme alle statistiche ufficiali e ai principali report di settore, evidenziano come **gli attacchi informatici ai danni delle PMI siano in costante aumento**².

L'uso preponderante di malware, ransomware e phishing, evidenzia come il cyber crimine sfrutti sempre più l'impreparazione in materia di cybersicurezza e l'errore umano a proprio vantaggio.

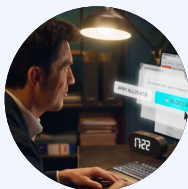
¹ ISTAT, Registro statistico delle imprese attive (2023), includendo le imprese con numero di addetti minore di 10 (microimprese) e le imprese con numero di addetti tra 10 e 250.

² Eurostat, Security incidents and consequences by size class of enterprise (2024); Nel 2024 il 15,8% delle imprese con numero di addetti tra 10 e 250 ha riportato di aver avuto nel corso dell'anno precedente almeno un problema di sicurezza ICT che ha determinato un impatto tra indisponibilità di servizi ICT, distruzione o corruzione dei dati, divulgazione di dati riservati (contro il 9,9% nel 2019).

Con l'introduzione di normative più recenti, come la Direttiva NIS2, **è essenziale che le PMI aumentino il loro presidio di sicurezza riducendo la superficie esposta alle minacce informatiche e mitigando gli impatti di eventuali attacchi cyber**, al fine di salvaguardare la produttività. In questa prospettiva, **oltre alle misure tecniche, assumono rilevanza cruciale le misure organizzative e procedurali** nelle quali la consapevolezza e la formazione **in materia di cybersicurezza** sono elementi centrali. Parimenti, è fondamentale la pianificazione dei processi per la gestione delle crisi e il controllo della catena di approvvigionamento (la c.d. supply chain).

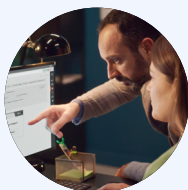


È fondamentale diffondere una buona cultura della cybersicurezza a tutti i livelli dell'organizzazione:



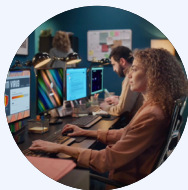
DIRIGENTI D'AZIENDA

affinché pianifichino attraverso l'allocazione di **budget e risorse**, l'acquisto di servizi e infrastrutture, e promuovano corsi di formazione o altre **iniziative di sensibilizzazione** volte al potenziamento di una cultura della cybersicurezza.



PROFESSIONISTI IT

affinché proteggano l'organizzazione dai rischi cyber, individuando, supportati dalla dirigenza, adeguate misure e iniziative di sicurezza atte a prevenire o ridurre le conseguenze di eventuali incidenti cyber, in conformità con le normative vigenti.



DIPENDENTI

affinché collaborino per il mantenimento della cybersicurezza aziendale, partecipando a iniziative di formazione e adottando le precauzioni suggerite dalla propria organizzazione al fine duplice di tutelarsi dalle minacce e contribuire in modo positivo al loro riconoscimento e alla mitigazione dei relativi impatti sull'organizzazione.

Nei paragrafi che seguono vengono presentate le principali indicazioni rivolte ai **professionisti e ai fornitori di servizi IT³**, con particolare attenzione alla dimensione aziendale delle imprese. Tali indicazioni illustrano i vantaggi e l'importanza di:

- **Rafforzare l'infrastruttura ICT aziendale.**
- **Prevenire e ridurre l'impatto degli incidenti di sicurezza cibernetica attraverso l'adozione di opportune misure di sicurezza.**

La guida supporta i professionisti e i fornitori di servizi IT nell'acquisire una maggiore consapevolezza sull'importanza del rispetto di buone pratiche di cybersicurezza nelle attività lavorative e nei processi operativi, al fine di sostenere l'innalzamento del livello di cybersicurezza complessivo dell'organizzazione. Per ciascun argomento, si riportano:



Una **sintesi** (o elenco di “**azioni chiave**”) che raccoglie i principali messaggi e comportamenti raccomandati in materia di cybersicurezza.



Contenuti in dettaglio: indicazioni operative strutturate sotto forma di linee guida.

N.B. Nel contesto di questo documento, per **informazioni riservate** si intendono **tutte quelle informazioni** trattate all'interno dei processi aziendali per cui è determinante garantire confidenzialità, e **la cui diffusione non autorizzata, alterazione, perdita può comportare un danno significativo per l'azienda e/o per i clienti e/o per altre parti coinvolte**. Queste informazioni possono includere dati personali, informazioni finanziarie, strategie aziendali, proprietà intellettuale, brevetti e altre informazioni. Tra le informazioni riservate sono incluse anche le cosiddette informazioni critiche ovvero le informazioni considerate particolarmente rilevanti per l'operatività e lo svolgimento del business dell'organizzazione.

³ Ovvero soggetti coinvolti nella gestione dell'ICT, dei sistemi informativi e dei dati e per questo interessati dalle specifiche tematiche di cybersicurezza qui indirizzate.

AZIONI NECESSARIE PER UN'IMPRESA PIÙ SICURA

1

Identifica le iniziative principali da promuovere in ambito cybersicurezza, con il supporto della dirigenza.

AZIONI CHIAVE

1. Pianifica e organizza annualmente iniziative di sensibilizzazione e formazione sulla cybersicurezza, individuando quelle più rilevanti per accrescere la consapevolezza e le competenze del personale.

2. Resta aggiornato sulle principali minacce e sulle migliori pratiche di cybersicurezza,

creando anche con altri attori del settore un ecosistema di difesa condiviso.

3. Individua i punti deboli della tua organizzazione e gli interventi necessari, considerando il business e gli obiettivi strategici della realtà aziendale.

CONTENUTI DI DETTAGLIO

Promuovere l'importanza della cybersicurezza all'interno di un'organizzazione è essenziale per garantire la protezione dei dati, la continuità operativa e la fiducia di clienti e stakeholder.

La difesa dei sistemi informatici, delle reti e dei dati, da minacce interne ed esterne che possono includere attacchi informatici, furti di dati e violazioni della privacy, è fondamentale per il business di qualsiasi organizzazione.

Per ottenere un'efficace promozione della cybersicurezza, infatti, oltre alla componente formativa e di sensibilizzazione, è indispensabile che le figure professionali esperte all'interno o all'esterno delle organizzazioni (nel caso ci si affidi a fornitori terzi) individuino ed implementino una serie di iniziative strategiche con il supporto della dirigenza. La partecipazione concreta dei professionisti IT al rafforzamento delle capacità di cybersicurezza deve essere riconosciuta e valorizzata come elemento distintivo nei processi interni di valutazione delle risorse umane.

E' opportuno sviluppare piani annuali di cybersicurezza che identifichino, in funzione delle capacità e delle risorse disponibili, dalle tre alle cinque iniziative prioritarie da attuare nel corso dell'anno. Tali iniziative devono essere orientate al rafforzamento del livello di protezione dell'organizzazione e alla **mitigazione dei rischi cyber**. La definizione di questi piani contribuisce, inoltre, alla costruzione di un ecosistema di difesa condiviso con gli altri attori del settore di riferimento.

Cosa si rischia con una mancata identificazione di iniziative da promuovere durante l'anno?

L'assenza di un piano strutturato per la **promozione della cybersicurezza** può tradursi in una scarsa consapevolezza, da parte del personale, rispetto alle responsabilità legate alla protezione dei dati e delle infrastrutture aziendali. Inoltre, comporta la perdita di un'importante opportunità di aggiornamento per i professionisti IT, che rischiano di non essere adeguatamente preparati ad affrontare le nuove minacce e ad applicare le migliori pratiche in materia di cybersicurezza.

La mancanza di iniziative cyber accresce l'esposizione al rischio dell'organizzazione aumentando così la probabilità di essere soggetta a vulnerabilità e a potenziali attacchi in grado di compromettere la continuità operativa e la protezione dei dati.

L'assenza di iniziative in ambito cybersicurezza espone l'organizzazione al rischio di non essere in grado di garantire una risposta tempestiva ed efficace in caso di incidenti informatici, oltre a comprometterne la capacità di aggiornarsi e adattarsi alle continue evoluzioni del panorama delle minacce cibernetiche.

⁴ Il numero potrebbe variare in funzione del budget a disposizione e di eventuali obiettivi specifici di miglioramento della postura cyber.

2

Valuta l'attivazione dell'autenticazione a più fattori o Multi Factor Authentication (MFA) ovunque ci sia la possibilità, dando priorità a strumenti di office automation; servizi di cloud storage; credenziali di accesso privilegiate a dati e piattaforme critiche; sistemi per accesso remoto.

AZIONI CHIAVE

1. Utilizza l'MFA per garantire che solo le persone autorizzate possano accedere ai dati personali e riservati.

2. Identifica eventuali altri servizi cruciali per il tuo business da proteggere tramite MFA e valuta di attivarla per i servizi verso la clientela.

3. Valuta, fra le varie opzioni di MFA, quelle più adatte alle esigenze dell'organizzazione e al livello di sicurezza richiesto dall'asset da proteggere.

4. Accertati di fornire, al personale dipendente ed esterno che la utilizza, tutte le informazioni per un corretto utilizzo dell'MFA e per mantenere al sicuro i codici di sicurezza. Assicurati che il fattore di autenticazione aggiuntivo sia protetto e accessibile solo al legittimo proprietario dell'account.

5. Usa l'MFA per i Sistemi per accesso da remoto, al fine di migliorare la cybersicurezza dell'organizzazione e ridurre il rischio di accessi non autorizzati.

CONTENUTI DI DETTAGLIO

I cybercriminali utilizzano tecniche sempre più avanzate per ottenere l'accesso non autorizzato ai sistemi e ai dati, il che comporta rischi significativi per la cybersicurezza delle organizzazioni. Per mitigare questi rischi, **è importante adottare buone pratiche di cybersicurezza che ostacolino l'attacco, tra cui l'abilitazione dell'autenticazione a più fattori o Multi Factor Authentication (MFA).** Pertanto, è necessario aggiungere più livelli di autenticazione, oltre a una password, per garantire che gli account e i dati in essi contenuti, rimangano protetti. Quando si attiva l'MFA per i servizi online (es. posta elettronica), si fornisce una combinazione di due o più fattori di autenticazione per verificare l'identità prima che il servizio conceda l'accesso.

Impostare l'autenticazione a più fattori è in genere un processo semplice e di breve durata ma il contributo che può dare è fondamentale, in quanto rende molto più difficile la riuscita dell'attacco per i cybercriminali che si concentreranno prima sugli account meno protetti. Pertanto, è fortemente consigliato a tutte le PMI, e non solo, di adottare dove possibile, l'autenticazione a più fattori, creando in questo modo un livello di sicurezza che aggiunga

protezione alle risorse aziendali riservate, rendendo più difficoltosa l'attività dell'attaccante. **Attivare l'MFA contribuisce a diminuire la possibilità di attacchi che partono dalla compromissione di account e credenziali.** Anche se un cybercriminale dovesse riuscire a compromettere uno dei fattori (es. la password di un dipendente), avrebbe comunque la necessità di realizzare un secondo tipo di attacco per soddisfare il secondo requisito di autenticazione, e così via, rendendo di fatto, all'aumentare dei fattori, sempre più difficile accedere all'account in modo illecito.

Opzioni più comuni di MFA

- **Gli SMS inviati a telefono cellulare o smartphone.**
- **I codici effimeri a 6 o più cifre e noti anche come codici OTP (One Time Password) generati da un'applicazione per smartphone.**
- **Le notifiche push inviate ai dispositivi.**
- **Le notifiche via e-mail.**
- **La biometria (es. impronta digitale).**
- **Le chiavi di sicurezza fisiche (es. chiavi USB, token rfid).**

Qualsiasi forma di MFA (es. i messaggi di testo SMS o i codici di autenticazione) aumenterà la difficoltà dell'attacco. Tuttavia, è importante bilanciare i benefici in termini di sicurezza con l'usabilità, evitando di introdurre eccessiva complessità nell'adozione di soluzioni più avanzate. Per questo motivo, è sempre raccomandata un'attenta valutazione, da condurre in funzione delle caratteristiche del sistema e delle specifiche esigenze dell'organizzazione.

È fortemente raccomandato valutare l'uso dell'MFA anche per i servizi verso la clientela. **L'adozione di un livello di cybersicurezza superiore grazie all'uso di MFA può aiutare l'organizzazione a migliorare la sua reputazione agli occhi dei clienti, dei fornitori e degli investitori.**

Come approccio per garantire un adeguato presidio si suggerisce di:

- **Individuare gli applicativi, i servizi, le utenze e le interfacce di accesso remoto più a rischio e più critici per l'organizzazione.**
- **Valutare le opzioni di MFA più adatte alle esigenze dell'organizzazione** e al livello di sicurezza richiesto.
- **Mettere a disposizione del personale che adotta l'MFA tutte le informazioni di sicurezza necessarie a garantire la riservatezza ed il corretto utilizzo di tali credenziali**, come ad esempio specifiche politiche, linee guida e procedure a supporto.

Per realtà più complesse si suggerisce, qualora possibile, di implementare sistemi di monitoraggio centralizzato, per rilevare eventuali accessi non autorizzati o attività sospette o di chiedere supporto a fornitori di servizi in grado di farlo.

Cosa si rischia non utilizzando l'MFA?

Se non viene attivata l'autenticazione a più fattori, aumenta il rischio di subire attacchi poiché senza l'MFA per un attaccante è sufficiente scoprire le password dei dipendenti per ottenere l'accesso ai loro account.

L'utilizzo di password semplici e il loro riutilizzo per account differenti aumenta il rischio di compromissione. Se viene utilizzata la stessa password per più account e uno di essi viene violato, è possibile che gli aggressori tentino di utilizzare le stesse credenziali per accedere ad altri account.

Non utilizzare l'MFA aumenta il rischio di perdita di dati, che a sua volta comporta la divulgazione di informazioni personali o finanziarie riservate a terzi non autorizzati.

3

Prevedi all'interno dei processi di Procurement l'adozione di requisiti e criteri di sicurezza per l'identificazione e la gestione dei tuoi fornitori. Valuta le implicazioni di sicurezza dei prodotti e servizi acquistati

AZIONI CHIAVE

1. Verifica sempre l'affidabilità dei fornitori prima della stipula di un contratto; verifica che il fornitore possieda determinate referenze prima di esternalizzare un servizio o acquistare un prodotto ICT.

2. Seleziona fornitori per i tuoi servizi che soddisfino adeguati livelli di sicurezza, che siano certificati e che forniscano garanzie sull'utilizzo delle migliori pratiche (es. ISO27001).

3. Identifica i dati, le informazioni e i processi impattati prima di esternalizzare un servizio o acquistare un prodotto ICT, al fine di valutare adeguatamente i rischi cyber ed eventuali vincoli normativi applicabili.

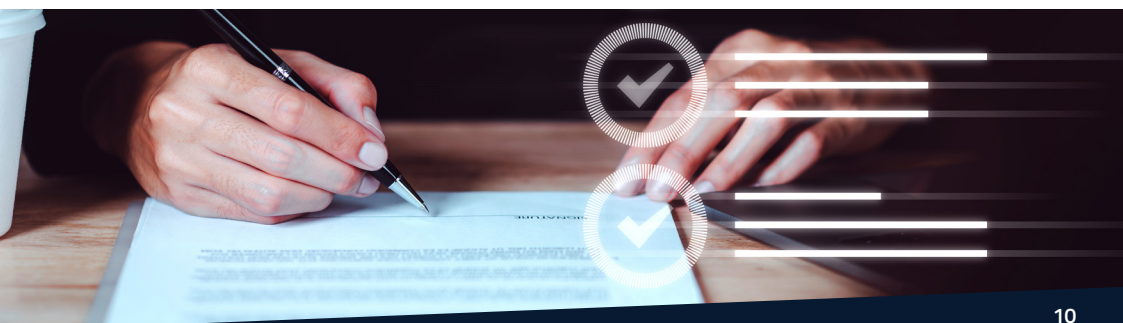
4. Definisci sempre formule contrattuali dettagliate a supporto delle attività esternalizzate e definisci requisiti più stringenti in funzione della criticità dei dati e dei servizi che affidi all'esterno.

5. Verifica che il fornitore abbia accesso esclusivamente alle informazioni strettamente necessarie per adempiere al contratto, applicando il principio del "privilegio minimo".

6. Verifica che nei contratti con le terze parti siano incluse oltre alle clausole di sicurezza quelle relative alla conformità ai vincoli normativi del tuo settore.

7. Verifica che nei contratti con le terze parti siano incluse clausole che richiedano l'esecuzione di attività di vulnerability assessment e/o penetration test per valutare il livello di sicurezza della sua infrastruttura e/o dei suoi prodotti.

8. Assicurati di prevedere opportune clausole per la gestione degli incidenti per ricevere supporto dalle terze parti in caso di necessità.



CONTENUTI DI DETTAGLIO

È importante garantire che tutti i fornitori, in particolare quelli che hanno accesso a dati e sistemi riservati o critici, soddisfino adeguati livelli di sicurezza concordati. Per questo motivo è fondamentale prevedere all'interno dei processi di procurement, l'adozione di requisiti e criteri di sicurezza per l'identificazione e la gestione dei fornitori, come è altrettanto importante valutare le implicazioni di sicurezza dei prodotti e servizi acquistati.

Ecco alcuni elementi chiave da cui partire per individuare il giusto fornitore. Prima di firmare il contratto, per capire il livello di sofisticazione del fornitore, o prima di acquistare un servizio e di firmare il relativo contratto, è importante tenere a mente alcuni passaggi:

- **Identifica i dati, le informazioni e i processi coinvolti per valutare adeguatamente i rischi cyber** ed eventuali vincoli normativi applicabili a cui il servizio o il prodotto ICT possa essere esposto.
- **Identifica il punto di contatto** presso il fornitore per i servizi specifici e chi sarà il referente e verifica, ove possibile, le sue referenze.
- **Informati sul livello dei controlli di sicurezza del fornitore e richiedi garanzie**, ad esempio se sono certificati e se rispettano le migliori pratiche di sicurezza (es. ISO27001).
- **Verifica gli accordi contrattuali** e assicurati che dispongano dei requisiti di sicurezza fondamentali per mitigare i rischi individuati per il servizio o il prodotto ICT in oggetto; in tale fase è opportuno nello specifico:
 - Identificare e proteggere adeguatamente gli eventuali accessi alle informazioni e ai sistemi dell'organizzazione necessari per l'erogazione del servizio.
 - **Garantire che sia sempre rispettato il principio del "privilegio minimo"**, in modo che il fornitore abbia accesso esclusivamente alle informazioni strettamente necessarie per svolgere le finalità del suo contratto.
 - Qualora non presenti, fare in modo che vengano inserite clausole relative a:
 - **Requisiti di sicurezza minimi da rispettare** che presidino trasversalmente gli accessi, la protezione dei dati, la rete, il backup e la gestione incidenti.
 - **La ricezione di reportistica** relativa ad eventuali incidenti occorsi.
 - **La conformità normativa** al contesto di riferimento.
 - **L'esecuzione di verifiche tecniche periodiche** (vulnerability assessment e/o penetration test) per valutare il livello di sicurezza dell'infrastruttura del fornitore e/o dei suoi prodotti, soprattutto nei casi in cui sono utilizzati a supporto dei processi critici dell'organizzazione.

E se la PMI è il fornitore?

Nel caso in cui una PMI sia fornitore di un ente soggetto alla Direttiva NIS/NIS2, sono previsti alcuni obblighi da tenere a mente per soddisfare i livelli minimi di sicurezza.

L'organizzazione dovrà rispettare almeno i seguenti requisiti:

- **Sottoporsi a un processo di valutazione del rischio.**
- **Garantire la continuità dell'approvvigionamento, l'assistenza e la manutenzione nel tempo.**
- **Partecipare al processo di notifica e segnalazione di incidenti di cybersicurezza.**
- **Applicare pratiche per garantire l'autenticità**
- e l'integrità del software o firmware che sarà presente all'interno dei beni e dei sistemi ICT.**
- **Verificare l'adeguatezza del codice sorgente.**
- **Sottoporsi ad audit periodici.**
- **Disporre di adeguate politiche di backup e ripristino dei dati per implementare un sistema più resistente e resiliente e fornire una migliore continuità operativa.**

Cosa comporta la non adozione di adeguate misure di sicurezza da parte dei fornitori?

La mancata adozione delle misure di sicurezza aumenta il rischio di accessi non autorizzati ai sistemi, con conseguente furto di informazioni riservate dell'organizzazione e/o dei clienti.

Una protezione inadeguata da parte del fornitore aumenta il rischio di attacchi informatici. Fornitori con sistemi non sicuri possono diventare bersagli di vari tipi di attacchi informatici, come attacchi DDoS, ransomware, phishing e altri, con gravi conseguenze economiche per l'organizzazione che si avvale dei suoi servizi.

La mancanza di conformità a standard e normative obbligatorie per il fornitore porta a violazioni normative sulla cybersicurezza e sulla privacy con conseguenti sanzioni legali e perdite economiche.

N.B. Per maggiori informazioni, consultare <https://www.acn.gov.it/portale/csirt-italia/glossario>

⁵ Decreto legislativo n. 65/2018 (Direttiva NIS) recepisce la Direttiva NIS (Network and Information Security) dell'Unione Europea, che stabilisce obblighi di sicurezza informatica per i fornitori di servizi essenziali e gli operatori di infrastrutture critiche. Tale norma è in fase di aggiornamento, stante l'entrata in vigore della Direttiva Europea NIS 2 (Direttiva UE 2022/2555) per la quale è previsto il recepimento a livello nazionale con l'introduzione di ulteriori misure e l'ampliamento dei settori coinvolti.



Utilizza, se compatibile con le esigenze della tua organizzazione, il mondo cloud nella sua versione Software-as-a-Service (SaaS) come leva per ridurre le competenze e gli sforzi necessari al mantenimento della sicurezza dei sistemi

AZIONI CHIAVE

1. Utilizza servizi di cloud Software-as-a-Service (SaaS) come tecnologia per ridurre le competenze e gli sforzi necessari al mantenimento della sicurezza dei sistemi.

2. Utilizza servizi di cloud SaaS per garantire livelli di sicurezza sempre elevati e aggiornati per le tue applicazioni, senza dover investire risorse interne e specifiche per questo compito.

3. Utilizza servizi di cloud SaaS per garantire alle applicazioni utilizzate nella tua azienda

l'installazione di aggiornamenti e patch di sicurezza automatiche e tempestive, eliminando la necessità di monitorare costantemente gli aggiornamenti e applicarli manualmente.

4. Identifica cosa realmente rimane sotto la tua responsabilità quando usi una soluzione SaaS in modo da definire cosa devi fare (es. gestione corretta dell'attribuzione di credenziali di accesso ed associazione al profilo necessario in funzione delle attività).

CONTENUTI DI DETTAGLIO

Il cloud è diventato un elemento fondamentale nelle strategie aziendali perché offre una vasta gamma di servizi, vantaggi e opportunità di innovazione sulla gestione dei sistemi informativi e delle funzioni IT. Esistono principalmente 3 tipologie di servizi basati sul cloud computing:

▪ **Infrastructure-as-a-Service (IaaS):** risorse infrastrutturali fisiche e virtuali (server, macchine virtuali, risorse di archiviazione e networking) su richiesta.

▪ **Platform-as-a-Service (PaaS):** strumenti e ambienti per lo sviluppo, il test,

la distribuzione e la gestione di applicazioni software.

▪ **SaaS: applicativi software, utilizzabili on-line, senza necessità di installazione locale.**

L'utilizzo del cloud, in particolare nella sua declinazione SaaS, rappresenta per le PMI una valida opportunità, a condizione che sia coerente con i requisiti di business e di sicurezza dell'organizzazione⁶. Questo approccio può contribuire a ridurre significativamente il carico operativo necessario per garantire la sicurezza dei sistemi. Quando si utilizza

⁶ È importante sottolineare che non tutte le organizzazioni possono fare affidamento sul cloud, e la possibilità di farlo dipende dalle esigenze specifiche dell'azienda. Alcune organizzazioni potrebbero non essere in grado di utilizzare il cloud per motivi normativi, di conformità o di sicurezza dei dati. Pertanto, la decisione di adottare il cloud deve essere sempre ponderata e basata su una valutazione approfondita dei rischi e delle esigenze aziendali.

un servizio SaaS, infatti, l'azienda si affida a un fornitore di servizi cloud che gestisce l'infrastruttura e l'applicazione stessa. Ciò significa che molte delle responsabilità e delle attività legate alla sicurezza, come la gestione delle patch, l'aggiornamento del software, la protezione dalle minacce e la gestione degli accessi, sono a capo del fornitore di servizi cloud.

Di seguito sono riportati alcuni esempi di come l'adozione di soluzioni SaaS possa contribuire concretamente a semplificare la gestione della cybersicurezza, riducendo il carico operativo interno e trasferendo parte delle responsabilità al fornitore di servizi.

▪ **Sicurezza gestita dal provider:** con SaaS, il provider del servizio si assume la responsabilità della gestione della sicurezza dell'applicazione; questo include la protezione dei dati, l'applicazione di patch di sicurezza e la gestione delle vulnerabilità. Di conseguenza l'organizzazione può affidarsi al provider per mantenere l'integrità e la sicurezza dell'applicazione senza dover investire risorse interne e specifiche per questo compito.

▪ **Aggiornamenti automatici:** i provider di SaaS qualificati generalmente gestiscono gli aggiornamenti e le patch di sicurezza

dell'applicazione in modo automatico e tempestivo. Questo riduce il carico di lavoro per il personale interno, eliminando la necessità di monitorare costantemente gli aggiornamenti e applicarli manualmente.

▪ **Monitoraggio della sicurezza:** le soluzioni SaaS più evolute includono servizi di monitoraggio della sicurezza integrati, che permettono di rilevare e contrastare tempestivamente eventuali minacce o violazioni. Ciò consente all'organizzazione di beneficiare di un livello di sorveglianza continuo, senza la necessità di disporre internamente di competenze specialistiche in materia.



Affidarsi a provider qualificati di servizi cloud per la gestione della sicurezza dell'applicazione può consentire all'organizzazione di concentrarsi sulle proprie attività principali senza compromettere la sicurezza dei dati e dei sistemi. Tuttavia, è importante ricercare all'interno dei contratti le garanzie sopra indicate e, qualora il servizio cloud gestisse la conservazione di dati personali, è fondamentale verificare che il loro trattamento non avvenga al di fuori dell'UE, come previsto dal General Data Protection Regulation (GDPR) e dalla normativa nazionale privacy.

Cosa comporta il mancato utilizzo del mondo cloud nella sua versione SaaS?

Il mancato utilizzo di un sistema cloud aumenta il rischio di impiegare ingenti risorse economiche in costi di infrastrutture iniziali (come l'acquisto di server, hardware e software) e di gestione ed acquisto di infrastrutture di sicurezza.

Il mancato utilizzo di un sistema cloud nella sua versione SaaS comporta il rischio di spendere molte risorse per rispondere ad incidenti di sicurezza informatica richiedendo competenze specializzate da parte dell'organizzazione.

Il mancato utilizzo di un sistema cloud nella sua versione SaaS può comportare il rischio di essere esposti più facilmente a vulnerabilità, costringendo il personale interno a monitorare costantemente gli aggiornamenti e applicarli manualmente piuttosto che utilizzare soluzioni di aggiornamento automatico e tempestivo.

5

Assicura l'aggiornamento dei sistemi operativi e delle applicazioni, attivando dove possibile gli aggiornamenti automatici. Fai in modo di non avere PC o smartphone con sistemi operativi non più supportati

AZIONI CHIAVE

1. Individua tutti gli asset e i dispositivi della tua organizzazione che richiedono un aggiornamento o patch di sicurezza.
2. Predisponi un inventario completo degli asset aziendali, classificando dispositivi e risorse in base alla loro criticità. Utilizza questa classificazione come base per stabilire le priorità negli interventi di aggiornamento e nell'installazione delle patch.
3. Assicurati che tutti i PC e smartphone in uso siano coperti da un servizio di assistenza e da un programma di patching attivo fornito dal vendor.
4. Aggiorna regolarmente, qualora possibile, seguendo pratiche di sicurezza riconosciute, tutti i tuoi asset e applica tempestivamente patch di sicurezza, fornite dai vendor.
5. Assicurati di scaricare gli aggiornamenti software solo da siti web di fornitori attendibili e assicurati di scaricare i bollettini di sicurezza dai siti dei vendor.
6. Prediligi gli aggiornamenti automatici ogniqualvolta possibile; assicurati che tali aggiornamenti automatici vengano effettuati solo da percorsi di rete attendibili (es. casa, lavoro) e che non ci siano incompatibilità con i software installati sui propri sistemi che possano creare disservizi.
7. Gestisci, se possibile, gli aggiornamenti e le patch di sicurezza tramite una piattaforma centralizzata.
8. Promuovi, a tutti i livelli dell'organizzazione, la consapevolezza dell'importanza di eseguire regolarmente gli aggiornamenti. Informa il personale sui rischi concreti a cui possono essere esposti dati e risorse aziendali qualora i criminali informatici riuscissero a sfruttare vulnerabilità non corrette da patch di sicurezza.

CONTENUTI DI DETTAGLIO

Gli aggiornamenti sono un elemento chiave nella strategia di gestione della cybersicurezza, in quanto aiutano le organizzazioni a mantenere un ambiente tecnologico sicuro, resiliente e allineato agli standard di sicurezza internazionali. Quando i fornitori rilasciano aggiornamenti software o patch di sicurezza, solitamente li rendono disponibili per il download attraverso i loro siti web o pubblicano bollettini di sicurezza. È importante che il team tecnico di addetti IT

consulti regolarmente, e, ove necessario, provveda ad installare gli aggiornamenti e le patch di sicurezza tempestivamente per proteggere le infrastrutture e gli asset da utenti malintenzionati che potrebbero sfruttare le vulnerabilità note e le debolezze dei sistemi per sferrare un attacco. Nel processo di gestione delle patch, è fondamentale definire criteri chiari per stabilire le priorità di intervento. Tra i principali fattori da considerare rientrano:

- la presenza di bug di sicurezza noti;
- il livello di criticità associato all'esposizione ad internet (superficie esposta);
- il livello di criticità associato alla vulnerabilità.

Diverso è il caso degli **aggiornamenti periodici, necessari per apportare miglioramenti, installare nuove funzionalità dei sistemi e correggere bug non bloccanti/critici per l'organizzazione**. Gli aggiornamenti possono essere installati manualmente o scegliere che si installino automaticamente:

Gli aggiornamenti automatici richiedono il consenso dell'utente o dell'amministratore durante l'installazione o la configurazione del software, e una volta ottenuto l'assenso gli aggiornamenti vengono "inviati" (o installati) automaticamente al sistema.

Gli aggiornamenti manuali richiedono che l'utente o l'amministratore visiti il sito web del vendor per scaricare e installare i file software.

L'implementazione di aggiornamenti automatici, quando possibile, semplifica e automatizza il processo di mantenimento della cybersicurezza, riducendo il rischio di esposizione a vulnerabilità dovute a ritardi nell'applicazione delle patch di sicurezza. Questo approccio proattivo è consigliato principalmente per proteggere le informazioni di natura riservata. È comunque consigliabile verificare preventivamente, in un ambiente di test, se l'installazione di aggiornamenti e patch possa causare incompatibilità tali da compromettere la disponibilità dei servizi.

Inoltre, qualora l'organizzazione lo permetta, è **importante valutare l'adozione di piattaforme centralizzate, in quanto permettono di automatizzare la distribuzione di aggiornamenti e patch di sicurezza su PC** (es. desktop o laptop), server, smartphone, ma anche applicativi, database e apparati di rete, sollevando il personale interno da questo compito.

Cosa si rischia con il mancato aggiornamento dei sistemi operativi e delle applicazioni e la non adozione delle linee guida per prioritizzare le attività di aggiornamento?

Gli aggiornamenti software spesso includono patch di sicurezza che correggono vulnerabilità note; **la mancata esecuzione di questi aggiornamenti espone le PMI a rischi di sicurezza informatica, come violazioni dei dati, malware, attacchi ransomware e altre minacce informatiche** così da diventare bersagli di attacchi mirati che sfruttano vulnerabilità non corrette.

La mancata adozione di linee guida per prioritizzare le attività di patching comporta il rischio di non aggiornare asset critici ed importanti per l'organizzazione e lasciarli vulnerabili agli attacchi cyber, mettendo a rischio la riservatezza, l'integrità e la disponibilità dei dati aziendali.

Gli aggiornamenti software non regolarmente applicati comportano problemi legati alle prestazioni, instabilità del sistema e crash del software, che possono interrompere le operazioni aziendali e causare perdite di produttività.

Se l'aggiornamento non viene scaricato dal sito del vendor si rischia di scaricare virus e malware e compromettere le funzionalità del sistema, nonché esporre l'organizzazione al furto di dati riservati con conseguenze economiche e reputazionali significative.



6

Abilita le funzionalità di cifratura dei dati su tutti gli asset possibili (es. PC, server, smartphone, dispositivi removibili) dell'organizzazione

AZIONI CHIAVE

1. Per PC, server, smartphone e altri dispositivi mobili, adotta le funzionalità di cifratura native offerte dal sistema operativo, preferendole ad alternative esterne quando possibile.

2. Non consentire l'utilizzo di dispositivi removibili senza le funzionalità di cifratura integrate.

3. Se non riesci a cifrare i dati direttamente sulla memoria dei tuoi dispositivi, fornisci indicazioni e linee guida per proteggerli con la crittografia prima di memorizzarli su dispositivi removibili.

4. Garantisci una comunicazione sicura attraverso la crittografia per proteggere le comunicazioni su reti pubbliche o non sicure, attraverso l'utilizzo di protocolli sicuri (es. https, TLS).

CONTENUTI DI DETTAGLIO

Con lo sviluppo della tecnologia, aumentano anche i rischi legati alle minacce cibernetiche e alla violazione della privacy. È quindi **essenziale adottare meccanismi di crittografia che proteggano i dati riservati dell'organizzazione**, sia quelli salvati in un sistema di archiviazione come database, file system o cloud storage, sia che quelli trasferiti tra dispositivi attraverso una rete o un canale di comunicazione.

La crittografia è un insieme di tecniche che permettono di proteggere e rendere inaccessibili i dati riservati consentendone una trasmissione sicura "in transito" e un'archiviazione protetta "a riposo". L'applicazione della crittografia su tutti i beni aziendali assicura la confidenzialità delle informazioni senza limitare l'uso dei dispositivi. Un esempio comune di crittografia è la cifratura dei dati su dispositivi digitali, come telefoni cellulari o laptop, mediante una chiave di cifratura.

Questa strategia è fortemente raccomandata perché i dati vengono trasformati in un formato cifrato mediante algoritmi di crittografia, risultando così illeggibili senza il possesso della chiave

di decrittazione, che può consistere, ad esempio, in una password o in un fattore di autenticazione biometrico, detenuto unicamente dall'utente autorizzato. Questo fornisce un primo livello di protezione dei dati aziendali anche nel caso in cui il dispositivo venga smarrito o rubato, o smaltito senza aver eseguito prima una procedura di cancellazione sicura, limitando in questo caso soprattutto il verificarsi di eventi di perdita di dati (data leakage).

Implementare la cifratura dei dati su tutte le risorse aziendali offre numerosi benefici alle piccole e medie imprese in termini di sicurezza dei dati, tutela della privacy e conformità alle normative.

Di seguito si riportano esempi di come sia possibile abilitare alcune tecniche di cifratura dei dati sui diversi tipi di asset:

- **PC (es. desktop o laptop) e server:** per questi dispositivi è possibile utilizzare un software di cifratura per crittografare l'intero disco rigido e proteggere così tutti i dati memorizzati sul dispositivo; in alternativa molti sistemi operativi di largo utilizzo offrono opzioni integrate per abilitare la cifratura del filesystem.

- **Smartphone e dispositivi mobili:** per questi dispositivi esistono modalità di cifratura native che ne permettono una cifratura completa. Inoltre, per questi asset può essere utile usare applicazioni di messaggistica istantanea ed e-mail che

offrano la cifratura end-to-end per proteggere i dati anche durante la trasmissione.

- **Dispositivi removibili:** molti dispositivi di archiviazione usb, schede di memoria e dispositivi di storage (es. hard disk esterni) offrono funzionalità di cifratura integrata; in alternativa un altro modo di applicare la cifratura è crittografare i dati prima di memorizzarli su dispositivi removibili. In questo caso è fondamentale fornire opportune linee guida agli utenti per aiutarli ad applicare queste operazioni in maniera

Infine, per garantire la sicurezza dei dati trasmessi tra dispositivi, è fondamentale assicurare una comunicazione sicura attraverso la crittografia, utilizzando protocolli affidabili (es. HTTPS, TLS) per proteggere le comunicazioni su reti pubbliche o insicure.



Cosa si rischia con una mancata cifratura dei dati su tutti gli asset dell'organizzazione?

Il mancato utilizzo di strumenti per la cifratura sui server dell'organizzazione facilita gli attaccanti nell'estrazione dei dati riservati o critici per il business, esponendola a furti di dati o violazioni della cybersicurezza e della privacy.

Il mancato utilizzo della cifratura sui dispositivi mobili facilita i malintenzionati ad accedere ai dati memorizzati sullo smartphone (es. e-mail, documenti aziendali o altre informazioni riservate) in caso di furto del dispositivo, mettendo a rischio la cybersicurezza e la reputazione dell'azienda.

Il mancato utilizzo della cifratura su dispositivi di archiviazione usb o hard disk esterni, in caso di smarrimento consente a chiunque di accedere a informazioni riservate.

7

Esegui e testa regolarmente i backup su tutti gli asset possibili (es. PC, server, smartphone, dispositivi removibili), dando priorità ai dati critici per la tua organizzazione

AZIONI CHIAVE

1. Identifica tutti i dispositivi che contengono dati importanti per l'organizzazione, come PC, server, smartphone e dispositivi removibili da sottoporre a backup.
2. Definisci politiche e linee guida per svolgere i backup in conformità con pratiche di sicurezza riconosciute e formalizzate in modo da avere sempre chiare le modalità operative impostate.
3. Pianifica il backup durante le ore notturne o comunque negli slot temporali in cui l'organizzazione non è nel pieno delle attività.
4. Programma procedure di backup automatico, quando possibile, altrimenti esegui in modalità manuale.
5. Garantisci che il backup sia conservato separatamente dall'ambiente di produzione.
6. Cripta il backup, soprattutto se gestisci dati riservati o critici per la tua organizzazione;
7. Esegui regolarmente i backup su tutti gli asset definiti (censiti nell'inventario degli asset dell'organizzazione) e in coerenza con le politiche prestabilite.
8. Configura adeguatamente i "log di backup" ed imposta notifiche automatiche dai software che ti aiutano a svolgere tali attività per assicurarti che non ci siano problemi nel processo.
9. Proteggi i dati di backup con un adeguato livello di protezione sia fisico/ambientale (es. controllo accessi fisico, sistemi di antincendio, sistemi di continuità) sia logico (es. controllo accessi logici cifratura).
10. Effettua test periodici di ripristino completo dei dati del backup.

CONTENUTI DI DETTAGLIO:

Un sistema di backup corretto e testato è essenziale per ripristinare rapidamente le operazioni aziendali in caso di compromissione dei dati, sia per cause accidentali che per attacchi volontari, come i ransomware. Tuttavia, durante un attacco, i dati potrebbero essere copiati, compromettendo la loro confidenzialità. In questi casi, il backup non protegge la riservatezza, ma è fondamentale per garantire la disponibilità e contribuire a mantenere l'integrità dei dati.

Come effettuare e gestire i backup

Il backup può essere effettuato su supporti di archiviazione come dischi rigidi esterni, unità di nastro, cloud storage o altri dispositivi di memorizzazione. Inoltre, sebbene possa essere programmato per eseguirsi automaticamente a intervalli regolari, è importante monitorarlo attentamente. In caso di ransomware, esiste infatti il rischio che vengano salvati anche dati cifrati, compromettendo la loro utilità per il ripristino. La scelta della modalità di backup dipende dalle esigenze specifiche dell'organizzazione, dalla criticità dei dati e dal budget allocato. Spesso, una combinazione di diverse modalità di backup (completo, differenziale e incrementale) può offrire una maggiore resilienza e protezione dei dati. Inoltre, effettuando regolarmente il backup dei dati, le organizzazioni possono limitare i danni derivanti da attacchi di tipo ransomware, diffusi tramite mail di phishing e siti web malevoli o compromessi, che ad oggi rappresentano le minacce più diffuse per le PMI.

La classificazione dei dati, in base al livello di criticità che questi rivestono all'interno dell'organizzazione è propedeutica a una corretta esecuzione del backup. Questo approccio consente di ottimizzare le risorse a disposizione, individuando chiaramente quali porzioni di dati sono critiche e necessitano di backup più frequenti e/o in siti isolati. In base alla criticità del dato, l'organizzazione può anche valutare l'opportunità di avere le repliche su siti remoti o comunque su porzioni di rete ulteriormente segmentate.

È necessario, quindi, sviluppare in conformità a pratiche di sicurezza riconosciute⁷ politiche, linee guida o procedure in materia per:

- **Stabilire i requisiti di sicurezza e di frequenza del backup di informazioni, software e configurazioni.**
- **Definire i requisiti di conservazione**
- **e cancellazione sicura dei dati in funzione delle finalità degli stessi.**
- **Definire indicazioni e/o procedure operative che possano aiutare nella loro esecuzione.**

Per il backup si suggerisce di seguire le seguenti indicazioni:

- **Identificare tutti i dispositivi che in coerenza con le politiche aziendali contengono dati importanti per l'organizzazione, come PC, server, smartphone e dispositivi removibili (es. dispositivi di archiviazione usb, hard disk esterni) da sottoporre al backup.**
- **Utilizzare un software affidabile per eseguire il backup dei dati; configurare il software con le opzioni desiderate, come l'inclusione di cartelle specifiche o tipi di file e verificare che esse siano adeguatamente protette.**

⁷ Cybersecurity Basics | NIST, Protecting Data from Ransomware and Other Data Loss Events: A Guide for Managed Service Providers to Conduct, Maintain, and Test Backup Files | CSRC (nist.gov)

- Creare, in coerenza con le politiche aziendali definite, una pianificazione regolare per eseguire i backup di tutti i dispositivi identificati. La frequenza può essere quotidiana, settimanale o mensile, a seconda dell'aggiornamento dei dati e dell'importanza degli stessi.
- Verificare, prima di sovrascrivere i vecchi backup, che le nuove versioni non presentino alterazione dei dati.
- Verificare che il backup sia effettuato regolarmente e definire delle attività di controllo periodiche, possibilmente formalizzate; è necessario, infatti, verificare che i backup siano correttamente impostati e che vengano completati senza errori.
- Garantire che il backup sia conservato separatamente dall'ambiente di produzione, così che la compromissione dell'uno non comporti la possibilità di accesso anche dell'altro.
- Criptare i backup, se contengono dati riservati o critici per l'organizzazione o se sono soggetti a spostamenti tra diversi luoghi.
- Verificare periodicamente la capacità di ripristinare regolarmente i dati dai backup; si raccomanda a tal fine di effettuare test periodici del loro funzionamento, dall'inizio alla fine, per non trovarsi in difficoltà in momenti critici. Testare le procedure di ripristino è importante anche per provare l'effettiva integrità dei file e verificare che siano recuperabili correttamente oltre che accessibili e utilizzabili come previsto.

Cosa comporta la mancata esecuzione del backup e dei loro test su tutti i possibili asset dell'organizzazione?

Se il backup non viene correttamente eseguito, in caso di compromissione o perdita dei dati, si rischia di perdere informazioni essenziali per l'organizzazione con gravi impatti sulle prestazioni e sulla reputazione dell'organizzazione.

In caso di interruzione dei servizi, l'assenza di una procedura di ripristino dei backup, comporta gravi impatti sulla continuità del business, in termini economici, fino a poter causare il fallimento dell'azienda e in termini reputazionali causati dall'incapacità di recuperare rapidamente i dati dopo un incidente.

La perdita di dati riservati, dovuta a una mancanza di esecuzione del backup, comporta violazioni di conformità normative sulla cybersicurezza e sulla privacy con conseguenti sanzioni legali e danni economici.



8

Garantisci che gli utenti non abbiano diritti amministrativi sul proprio PC

AZIONI CHIAVE

1. Garantisci che gli account utente non abbiano diritti amministrativi sul proprio PC, in quanto potrebbero disabilitare configurazioni di sicurezza o utilizzare erroneamente diritti privilegiati esponendo l'organizzazione a maggiori rischi cyber.
2. Configura gli account degli utenti affinché abbiano i privilegi minimi richiesti per eseguire le attività loro assegnate ed il giusto "need to know" per visionare e utilizzare esclusivamente le informazioni necessarie alla propria attività lavorativa.
3. Garantisci una adeguata "separation of duties" nei processi aziendali; non assegnare a singoli account profili che potrebbero generare conflitti nei processi autorizzativi aziendali.
4. Evita l'assegnazione di utenze con privilegi elevati o limitale al personale strettamente necessario, qualificato come "amministratore di sistema", obbligando, inoltre, quest'ultimo a usare account de-privilegiati per le operazioni quotidiane.
5. Disattiva gli account di amministratore locale e gli account amministrativi di default di prodotti o sistemi.
6. Prevedi adeguati presidi e misure di controllo aggiuntive per proteggere i tuoi account amministrativi.
7. Prevedi processi di review periodica degli account e dei diritti di accesso assegnati per tenere sempre sotto controllo le abilitazioni ai sistemi dell'organizzazione.

CONTENUTI DI DETTAGLIO

L'assegnazione dei diritti di accesso è un aspetto determinante per garantire l'integrità, la confidenzialità e la disponibilità dei dati e dei sistemi informatici e **tutto il personale dovrebbe avere assegnati i diritti di accesso in linea con le proprie mansioni e le finalità di business.** Limitare i diritti amministrativi degli utenti è infatti fondamentale per contenere gli impatti di errori volontari o involontari e assicurare che non vengano disabilite le impostazioni di sicurezza definite sugli asset aziendali.

Gli utenti generici (anche definiti, account utente o account generici) non devono avere diritti amministrativi sul proprio PC per diverse ragioni:

- **Gli utenti che dispongono dei diritti amministrativi, infatti, possono modificare le impostazioni di sicurezza, apportare modifiche critiche al sistema, installare software potenzialmente dannosi e di conseguenza aumentare esponenzialmente il rischio di violazioni di sicurezza e di attacchi informatici.**
- **Gli utenti che dispongono di privilegi amministrativi non necessari possono mettere a rischio i dati riservati presenti su aree condivise; infatti, potrebbero accedere a cartelle o file critici ed eliminare o alterare dati importanti accidentalmente o intenzionalmente.**



L'assegnazione di diritti privilegiati solo agli amministratori consente, dunque, di controllare e garantire l'integrità del sistema operativo e delle applicazioni installate, nonché migliorare la sicurezza dei dati. Gli account utente, quindi, dovrebbero essere configurati con limitati diritti e privilegi, che impediscono loro di effettuare modifiche sulle impostazioni native e di sicurezza dei propri dispositivi o, possibilmente, di installare software non autorizzati sui propri supporti. Per tale motivo, per gli accessi generici è fondamentale:

- **Garantire un'adeguata "separation of duties" nei processi aziendali; non assegnare a singoli account profili che potrebbero generare conflitti nei processi autorizzativi aziendali.**
- **Evitare di assegnare privilegi elevati o limitarli al personale strettamente necessario e qualificato come "amministratore di sistema"; obbligando, inoltre, questi ultimi a usare account de-privilegiati per le operazioni quotidiane (come la lettura di e-mail e la navigazione in Internet).**
- **Implementare il modello di controllo degli accessi basato sui ruoli (RBAC, Role-Based Access Control), che consente di assegnare i permessi agli utenti in base al ruolo specifico all'interno dell'organizzazione, facilitando così la gestione degli accessi e l'enforcement delle politiche di sicurezza. Questo modello supporta anche una più semplice gestione dei trasferimenti di personale all'interno dell'azienda, migliorando l'efficacia e la conformità delle politiche di sicurezza interna.**
- **Prevedere processi di review periodica degli account e dei diritti di accesso assegnati per tenere sempre sotto controllo le abilitazioni concesse ai sistemi dell'organizzazione.**

Ulteriori indicazioni per gestire correttamente gli accessi amministrativi

È importante tenere presente che ogni organizzazione ha esigenze diverse in termini di sicurezza e restrizioni degli accessi; quindi, le misure specifiche da implementare possono variare a seconda delle realtà e della complessità dell'organizzazione di riferimento. È sempre buona norma che l'assegnazione dei diritti amministrativi sia controllata attraverso un processo di autorizzazione in conformità con una specifica politica sul controllo degli accessi definita e delineata dall'organizzazione.

Per gestire correttamente gli accessi amministrativi è consigliato:

- **Adottare per i diritti di accesso privilegiati requisiti di autenticazione più elevati; ad esempio, prima di lavorare con diritti di accesso privilegiati può essere necessaria una nuova autenticazione o un ulteriore passaggio di autenticazione (MFA).**
- **È fondamentale proteggere in modo adeguato le credenziali di autenticazione degli account privilegiati, valutando l'adozione di strumenti dedicati alla conservazione sicura delle password, come i password manager. A tal fine, è consigliabile definire politiche, linee guida o procedure specifiche da condividere con l'intera organizzazione⁸, tenendo presente che anche il password manager stesso rappresenta un potenziale punto di attacco e deve quindi essere opportunamente protetto.**
- **Disattivare gli account di amministratore locale e gli account amministrativi di default di prodotti o sistemi.**
- **Stabilire regole specifiche per evitare l'uso di ID utente di amministrazione generici (come "root"), a seconda delle capacità di configurazione dei sistemi.**
- **Laddove possibile, per attività di manutenzione o modifiche critiche, l'accesso privilegiato dovrebbe essere concesso esclusivamente per il tempo strettamente necessario all'esecuzione delle operazioni. In scenari straordinari, ad esempio blocchi operativi o necessità di intervento urgente, si può ricorrere alla procedura detta "Break the Glass". Questa prevede un accesso eccezionale, temporaneo e tracciato a risorse critiche. In ogni caso, è essenziale documentare con precisione ogni intervento, indicando le operazioni eseguite, l'autorizzazione ricevuta e il personale coinvolto.**
- **Per finalità di audit e controllo, è opportuno prevedere la registrazione e il monitoraggio degli accessi da parte degli utenti privilegiati, al fine di rilevare eventuali tentativi non autorizzati di acquisire diritti amministrativi. Ciò consente di individuare tempestivamente eventuali violazioni e di adottare le misure correttive più appropriate.**

⁸ Possibilmente, suggerendone l'utilizzo anche per gli account generici.

- Evitare la condivisione di identità con diritti di accesso privilegiato tra più utenti. Ogni persona deve disporre di un'identità separata, a cui siano associati esclusivamente i diritti di accesso necessari in base al ruolo e alle responsabilità assegnate.
- Effettuare revisioni periodiche degli utenti con diritti di accesso privilegiato, in particolare

a seguito di cambiamenti organizzativi, per verificare che i ruoli, i compiti e le responsabilità assegnate giustifichino ancora tali abilitazioni. Questo processo è essenziale per individuare situazioni in cui gli accessi non sono più necessari, ad esempio in caso di cambio di mansione o di cessazione del rapporto di lavoro.

Cosa comporta la mancata limitazione dei diritti amministrativi degli utenti sul proprio PC?

La mancanza di un'adeguata limitazione dei diritti amministrativi comporta il rischio di accessi non autorizzati a informazioni riservate, manomissione erronea o volontaria delle stesse o attività non autorizzate, compromettendo la cybersicurezza dell'organizzazione e dei clienti.

L'assegnazione di diritti amministrativi ad utenti generici aumenta il rischio di modifiche alle impostazioni di sicurezza del sistema, disabilitando antivirus o consentendo agli utenti di superare le policy dell'organizzazione abilitandoli ad azioni potenzialmente dannose che aumenterebbero esponenzialmente il rischio di violazioni di sicurezza e di attacchi informatici.

La mancanza di competenze specifiche o di una formazione adeguata in capo a utenti con diritti amministrativi comporta il rischio che questi commettano errori che potrebbero causare problemi operativi o perdite di dati, con gravi danni economici per l'organizzazione.

Se non si adottano buone pratiche nella gestione delle utenze amministrative di sicurezza, aumenta il rischio che tali account diventino potenziali bersagli di attacchi informatici; i cybercriminali spesso prendono di mira questi account per ottenere accesso ai sistemi aziendali e comprometterne la sicurezza.

9

Garantisci l'installazione e l'aggiornamento di una soluzione di sicurezza endpoint (es. antivirus, antimalware, Unified Threat Management - UTM, Next Generation Firewall - NGFW) su tutti gli asset (es. PC, server, smartphone) dell'organizzazione

AZIONI CHIAVE

1. Identifica tutti gli asset che richiedono una protezione endpoint e seleziona per ognuno la soluzione che ritieni più consona.

2. Prediligi, se possibile, l'adozione di una soluzione endpoint gestita a livello centrale che permetta di monitorare tutti i dispositivi da un'unica consolle, centralizzandone l'aggiornamento e massimizzandone l'efficacia operativa.

3. Garantisci l'aggiornamento regolare del software e delle firme, in quanto contengono

le ultime definizioni di virus e le correzioni di sicurezza più recenti.

4. Monitora il corretto funzionamento dell'antivirus per assicurarti che tutti i dispositivi siano regolarmente protetti e, qualora ci fossero problemi, intervieni prontamente.

5. Utilizza, dove possibile, soluzioni endpoint che includono funzionalità per filtrare lo spam e rilevare e-mail di phishing.

CONTENUTI DI DETTAGLIO

L'installazione e l'aggiornamento di soluzioni antivirus su tutti gli asset possibili dell'organizzazione è fondamentale per proteggere l'organizzazione da minacce informatiche. **La protezione degli asset aziendali rappresenta la prima linea di difesa in ambito di sicurezza informatica ed è uno degli ambiti prioritari in cui le organizzazioni concentrano gli sforzi per tutelare i propri dati all'interno delle reti aziendali.** L'antivirus è uno degli strumenti inclusi nelle soluzioni di endpoint protection, le quali offrono una protezione avanzata contro malware sofisticati e minacce zero-day in continua evoluzione. Ogni organizzazione dovrebbe selezionare le soluzioni di sicurezza più adeguate in base alla tipologia e al valore degli asset da proteggere, al fine di garantire un livello di protezione efficace.

Per questa selezione è importante quindi:

- **Valutare le funzionalità aggiuntive più adatte per il contesto tecnologico ed organizzativo.**

- **Valutare l'impatto sulle performance del sistema per evitare rallentamenti operativi.**

- Valutare l'affidabilità della soluzione attraverso test e certificazioni rilasciate da laboratori indipendenti riconosciuti.

Linee guida per il ciclo di vita di installazione e aggiornamento della protezione endpoint

- Identificare come primo passo tutti gli asset che richiedono una protezione endpoint.
- Selezionare la soluzione di protezione endpoint più adeguata in base alla tipologia di dispositivo da proteggere.
- Procedere all'installazione della soluzione di protezione endpoint su tutti gli asset identificati, preferendo, ove possibile, soluzioni gestite centralmente. Tali soluzioni consentono di monitorare e amministrare tutti i dispositivi da un'unica consolle, centralizzando gli aggiornamenti e garantendo una maggiore efficacia operativa.
- Garantire l'aggiornamento regolare del software e delle firme, poiché contengono le ultime definizioni di virus e le correzioni di sicurezza più recenti.
- Monitorare costantemente il corretto funzionamento della protezione endpoint, verificando che tutti i dispositivi risultino protetti e intervenendo tempestivamente in caso di malfunzionamenti o anomalie.
- Sensibilizzare gli utenti sull'importanza dell'utilizzo della protezione endpoint, promuovendo comportamenti corretti e consapevoli nell'uso quotidiano dei dispositivi.



Ulteriori indicazioni per rafforzare il presidio

Per garantire l'installazione e l'aggiornamento di una soluzione di protezione endpoint su tutti gli asset possibili dell'organizzazione si riportano le principali raccomandazioni da seguire:

- **Rivedere regolarmente la politica anti-malware, avvalendosi anche del supporto di esperti di settore, per mantenerla aggiornata rispetto alle minacce esistenti e al contesto aziendale/tecnologico.**
- **Installare su PC, server e nodi di comunicazione diverse tecnologie di protezione anti-malware, per poter usufruire di capacità di rilevamento incrociato; dove possibile, valutare anche l'adozione di**

soluzioni più evolute, come ad esempio strumenti moderni di protezione Security Orchestration, Automation and Response (SOAR).

- **Analizzare periodicamente il panorama delle minacce informatiche, avvalendosi di fonti pubbliche e private o del supporto di organismi specializzati, al fine di rafforzare il presidio sulle soluzioni tecnologiche adottate.**

Cosa comporta la mancata installazione e l'aggiornamento di una soluzione di protezione endpoint su tutti gli asset dell'organizzazione?

La mancanza di una soluzione di protezione endpoint rende i sistemi vulnerabili a malware, virus, worm, trojan e ransomware e ad altri software dannosi. Queste minacce possono mettere a rischio la sicurezza dei dati, causando gravi incidenti di sicurezza e compromettendo l'operatività e la reputazione dell'azienda.

L'assenza di una soluzione di protezione endpoint, efficace e regolarmente aggiornata, facilita l'accesso non autorizzato ai dati riservati o la loro perdita, con conseguente furto di informazioni personali, password, dati bancari e altre informazioni riservate, mettendo così a rischio la cybersicurezza e la privacy non solo dell'utente, ma anche dell'intera organizzazione.

Un'implementazione scorretta della soluzione di protezione endpoint porta gli utenti ad essere vittime di spyware, un tipo di malware che monitora l'attività online degli utenti senza il loro consenso. Questo può comportare la raccolta di informazioni personali, l'accesso a password e la registrazione delle attività online, con conseguente violazione della cybersicurezza e della privacy.

10

Definisci, implementa e mantieni aggiornate le soluzioni tecniche per gestire adeguatamente l'accesso remoto dei tuoi dipendenti e fornitori (es. VPN, modelli Zero Trust)

AZIONI CHIAVE

1. Definisci e implementa le soluzioni tecniche che garantiscono adeguatamente l'accesso remoto dei dipendenti e fornitori; usa strumenti di sicurezza online, come le VPN, per proteggere la connessione internet e i dati durante la navigazione.
2. Aggiorna regolarmente le soluzioni tecniche per supportare l'accesso remoto in maniera adeguata.
3. Applica password forti per l'accesso remoto e, dove possibile, attiva l'autenticazione a più fattori.
4. Garantisci l'accesso alla tua rete solo a dispositivi che soddisfino i requisiti di sicurezza della tua organizzazione.
5. Garantisci che gli accessi dei fornitori o di altre parti esterne siano identificati e limitati ai requisiti di business.
6. Garantisci che tutte le tipologie di accesso remoto da parte dei tuoi fornitori siano concordate e formalizzate nei contratti di servizio.
7. Assicurati di disporre e fornire ai dipendenti indicazioni (es. linee guida, politiche) che governino gli accessi remoti, e che venga spiegata loro l'importanza di seguirle.

CONTENUTI DI DETTAGLIO

Governare gli accessi remoti è un tassello importante per la sicurezza della rete dell'organizzazione. È bene quindi definire, implementare e mantenere aggiornate una serie di soluzioni tecniche per supportare l'accesso sicuro di dipendenti e fornitori alla rete aziendale dell'organizzazione.

Soluzioni tecniche che supportano l'accesso da remoto

Per garantire un accesso remoto sicuro da parte di dipendenti e fornitori, è fondamentale individuare soluzioni tecniche adeguate, da integrare con ulteriori misure di sicurezza. Tra queste, si raccomanda l'adozione dell'autenticazione a più fattori, il monitoraggio delle attività degli utenti e l'aggiornamento periodico dei software e delle infrastrutture di rete.

Le principali soluzioni ad oggi disponibili per supportare l'accesso sicuro da remoto sono:

▪ **La Virtual Private Network (VPN), o rete privata virtuale, è una tecnologia che consente di stabilire una connessione sicura e crittografata su una rete pubblica come Internet.** L'utilizzo della VPN permette agli utenti di accedere in modo riservato e protetto alle risorse aziendali, garantendo la sicurezza dei dati trasmessi e la continuità operativa anche da remoto. Una volta stabilita la connessione VPN, è possibile svolgere le proprie attività lavorative accedendo ai principali servizi informatici aziendali, tra cui:

- Utilizzare la posta elettronica tramite la rete interna o mediante client dedicati.
- Accedere a cartelle condivise e repository aziendali (es. file server, strumenti collaborativi di elaborazione documenti).
- Effettuare l'accesso alle applicazioni tramite la Intranet aziendale.
- Accedere ai server dell'organizzazione.

▪ **Soluzioni di accesso remoto basate su cloud:** esistono numerose soluzioni basate su cloud che offrono accesso remoto sicuro per le organizzazioni⁹. Queste soluzioni consentono ai dipendenti di accedere in modo protetto ai dati e alle applicazioni aziendali tramite una connessione Internet sicura. Alcuni fornitori offrono anche funzionalità di gestione dei dispositivi e di sicurezza avanzata per proteggere l'accesso remoto.

▪ **Garantire l'utilizzo di una VPN per i dati in transito su reti pubbliche,** quali reti Wi-Fi di alberghi o aeroporti per mantenere adeguati livelli di sicurezza e privacy.

▪ Se si utilizzano servizi cloud, **è preferibile la scelta di un Secure Internet Gateway,** che garantisce un accesso e una connessione protetta alla rete.

▪ **Assicurarsi che tutti i software utilizzati per l'accesso remoto siano correttamente configurati e costantemente aggiornati,** sia in termini di versione applicativa che di patch di sicurezza.

▪ **Limitare l'accesso remoto** del personale ai soli sistemi e PC necessari per lavorare.

▪ **Applicare, password forti e complesse** per l'accesso remoto e, dove possibile, attivare l'autenticazione a più fattori o MFA.

▪ Implementare misure tecniche che, prima di autorizzare la connessione di qualsiasi dispositivo appartenente a dipendenti o fornitori alla rete aziendale, verifichino il rispetto dei requisiti minimi di sicurezza definiti dall'organizzazione.

▪ Garantire il monitoraggio e l'attivazione di alert per segnalare attacchi sospetti o attività insolite.

▪ **Valutare l'implementazione di un modello basato su Zero-Trust per l'accesso remoto.**

⁹ È importante sottolineare che non tutte le organizzazioni possono fare affidamento sul cloud, e la possibilità di farlo dipende dalle esigenze specifiche dell'azienda. Alcune organizzazioni potrebbero non essere in grado di utilizzare il cloud per motivi normativi, di conformità o di sicurezza dei dati. Pertanto, la decisione di adottare il cloud deve essere sempre ponderata e basata su una valutazione approfondita dei rischi e delle esigenze aziendali.

Inoltre, con particolare riferimento ai fornitori o ad altre parti esterne è importante garantire che:

- Tutte le tipologie di accesso da remoto, inclusi gli accessi per attività di manutenzione straordinaria, siano concordate e formalizzate attraverso specifiche disposizioni contrattuali.
- Gli accessi da remoto siano identificabili, monitorati e limitati esclusivamente alle attività necessarie e coerenti con i requisiti di business,

Come supportare l'accesso sicuro

Il personale all'interno dell'organizzazione deve essere formato adeguatamente per rendere sicuro l'accesso remoto. A tal fine, è importante:

- Includere informazioni sull'accesso remoto sicuro all'interno dei corsi di formazione regolarmente erogati e negli orientamenti rivolti al nuovo personale.
- Disporre e fornire indicazioni (es. procedure, istruzioni operative) che governino gli accessi remoti, e spiegare al personale l'importanza di attenersi scrupolosamente a tali indicazioni.
- Informare il personale sui rischi connessi all'utilizzo di reti Wi-Fi pubbliche e sulla necessità di utilizzare una VPN o un Secure Internet Gateway per accedere da remoto alla rete aziendale.
- Sensibilizzare tutto il personale, tramite politiche, linee guida o procedure basate su pratiche di sicurezza riconosciute¹⁰, sull'importanza dell'utilizzo di connessioni sicure all'interno dell'organizzazione, al fine di proteggere le informazioni trasmesse attraverso reti Wi-Fi.



¹⁰ Rif. Cybersecurity Basics | NIST, SP 800-46 Rev. 2, Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security | CSRC (nist.gov).

Cosa comporta la mancata adozione di soluzioni tecniche per supportare l'accesso remoto dei tuoi dipendenti e fornitori?

La mancanza di protezione dell'accesso remoto aumenta il rischio di perdita o furto di dati riservati.

La mancata adozione di soluzioni tecniche a supporto dell'accesso remoto da parte dei dipendenti e fornitori, facilita i cybercriminali a condurre attacchi informatici mirati, ad esempio attraverso la diffusione di malware, ransomware o exploit delle vulnerabilità del software.

Senza un accesso remoto sicuro, si aumenta il rischio che dipendenti o fornitori possano essere vittime di attacchi di phishing poiché costretti ad utilizzare e-mail non sicure o dispositivi non protetti per accedere alle risorse aziendali.

Senza un accesso remoto affidabile e sicuro i dipendenti possono incontrare difficoltà nello svolgimento delle proprie mansioni, rallentando di conseguenza i processi aziendali.

11

Individua attività, sistemi, servizi e dati critici per l'organizzazione per prioritizzare le iniziative cyber. Identifica opportune metodologie di identificazione e monitoraggio periodico delle minacce di sicurezza che potrebbero impattare i tuoi asset

AZIONI CHIAVE

1. Effettua regolarmente un'analisi del rischio cyber, anche con il supporto di professionisti, per identificare le minacce associate ad asset, risorse e sistemi, e adottare misure di mitigazione adeguate.

2. Adotta una strategia di monitoraggio delle minacce, per identificare e rispondere in modo tempestivo alle potenziali minacce di sicurezza; se non disponi delle competenze necessarie, individua un professionista

qualificato che si occupi di curare per te tali analisi.

3. Informati e verifica regolarmente la disponibilità di finanziamenti o incentivi che possano supportare il rafforzamento del livello di cybersicurezza della tua organizzazione.

CONTENUTI DI DETTAGLIO

In un panorama digitale sempre più complesso, **introdurre una strategia efficace di sicurezza informatica è essenziale per proteggere le attività, i sistemi, i servizi e i dati critici di un'azienda.**

Rendere prioritarie le iniziative cyber risulta fondamentale e richiede una valutazione adeguata dei rischi e delle vulnerabilità specifiche dell'azienda, tenendo conto del contesto operativo, delle tecnologie utilizzate e delle minacce emergenti nel panorama della cybersicurezza. Per attuare un approccio efficace, è indispensabile individuare con chiarezza i sistemi, i servizi e i dati più critici, nonché disporre di un inventario aggiornato degli asset dell'organizzazione. Sulla base dell'inventario prodotto e aggiornato nel tempo, **l'organizzazione dovrebbe concentrare l'attenzione su quelli più critici, avviando una valutazione del rischio finalizzata a stabilire priorità tra processi e attività, in relazione ai potenziali impatti sul business.** Tale analisi supporta anche la continuità operativa e consente di pianificare e attuare gli interventi in ambito cyber.

Le iniziative cyber dovrebbero essere quindi identificate per garantire un'elevata protezione degli asset critici e assicurare la resilienza operativa, la conformità normativa e la fiducia dei clienti, proteggendo simultaneamente l'azienda da potenziali perdite finanziarie, danni alla reputazione e conseguenze legali derivanti da violazioni della sicurezza.

Monitoraggio delle minacce

Oltre alla valutazione dei rischi, è altrettanto essenziale implementare un monitoraggio continuativo delle minacce informatiche, per rilevare tempestivamente nuovi vettori di attacco e rispondere efficacemente.

In funzione della complessità dell'organizzazione, della criticità dei dati trattati e dei servizi erogati all'esterno, è possibile valutare di rivolgersi ad un fornitore specializzato in servizi di sicurezza gestiti. In alternativa, è possibile valutare gli strumenti già presenti in azienda, sfruttandone le funzionalità di alerting in tempo reale — ad esempio mediante la configurazione dell'invio automatico di notifiche via e-mail al reparto ICT o al responsabile della cybersicurezza — attivando così un monitoraggio proattivo di eventi anomali prima che si trasformino in potenziali violazioni o interruzioni operative. Le attività di identificazione e monitoraggio possono includere, dove compatibile con la complessità organizzativa e la natura dei dati trattati, anche l'adozione di una soluzione SIEM (Security Information and Event Management). Questo tipo di strumento consente di centralizzare il monitoraggio degli eventi di sicurezza generati da dispositivi e sistemi aziendali, correlare e analizzare i dati provenienti da diverse fonti, e rafforzare le misure di protezione esistenti, come firewall, sistemi di rilevamento delle intrusioni (IDS/IPS), antivirus e soluzioni di endpoint protection.

Alcune regioni italiane hanno messo a disposizione delle PMI bandi per incentivare l'adozione di queste tecnologie attraverso voucher finanziati per la "Digitalizzazione e Cybersicurezza". Informarsi sul tema è estremamente importante e offre molti vantaggi. **Approfondire la presenza di finanziamenti o supporti per innalzare il livello di cybersicurezza dell'organizzazione potrebbe fare la differenza.**

Cosa comporta la mancanza di consapevolezza sull'importanza della gestione e del monitoraggio delle minacce a cui sono esposti gli asset aziendali?

La scarsa consapevolezza riguardo ad asset, attività, sistemi, servizi e dati — soprattutto se critici — aumenta il rischio che l'organizzazione non sia adeguatamente preparata a fronteggiare attacchi informatici. Lo sfruttamento di vulnerabilità non note può infatti causare gravi danni operativi ed economici, fino alla sospensione delle attività aziendali.

Senza una strategia che aiuti a gestire i rischi e a dare priorità alla cybersicurezza degli asset più critici, l'organizzazione rischia di investire risorse in modo inefficace, concentrandosi su contromisure secondarie e trascurando il reale potenziamento delle proprie capacità di difesa.

L'assenza di attività o di servizi dedicati all'identificazione e al monitoraggio delle minacce emergenti impedisce all'organizzazione di attuare misure preventive e proattive, aumentando il rischio che tali minacce si traducano in danni agli asset aziendali.

12

Limita l'esposizione a Internet alle sole piattaforme essenziali per l'operatività aziendale.

AZIONI CHIAVE

1. Individua tutte le piattaforme della tua organizzazione con accesso a Internet.
2. Seleziona esclusivamente quelle strettamente necessarie per le tue finalità di business e chiudi l'accesso ad Internet alle piattaforme per cui la connessione non sia necessaria così da ridurre la superficie di attacco.
3. Prevedi un'adeguata protezione delle piattaforme che espongono servizi ad internet, sviluppando o chiedendo supporto ai tuoi fornitori di servizi per adottare misure di protezione elevate in funzione della criticità dei dati e dei servizi erogati.
4. Garantisci l'adozione di firewall, DMZ, autenticazione a più fattori e riduci al minimo indispensabile gli account amministrativi utilizzando VPN (per crittografare le connessioni e proteggere i dati).
5. Garantisci l'esecuzione di attività di vulnerability assessment e/o penetration test periodici per identificare prontamente e correggere eventuali falle di sicurezza.
6. Predisponi, o richiedi al tuo fornitore, un piano di risposta agli incidenti, per garantire una gestione efficace di eventuali violazioni della sicurezza o altri eventi critici.

CONTENUTI DI DETTAGLIO

Il crescente livello di digitalizzazione comporta che anche organizzazioni siano molto più esposte verso l'esterno.

Ridurre il numero di piattaforme che espongono servizi su internet, e quindi la loro superficie di attacco, e contestualmente implementare misure di sicurezza specifiche, contribuisce notevolmente a proteggere l'organizzazione e i suoi dati riservati, riducendo i rischi di restare vittima di attacchi informatici.

Questo approccio consente inoltre di concentrare le risorse e l'attenzione sulle piattaforme più esposte, riducendo al minimo l'esposizione alle potenziali minacce e il rischio di interruzioni operative.



Per garantire un'adeguata protezione delle piattaforme esposte, è fondamentale implementare, direttamente o tramite il fornitore esterno, misure specifiche che includano:

- L'impiego di firewall e, nel caso di applicazioni web, di Web Application Firewall (WAF) rappresenta una misura fondamentale per la protezione dell'infrastruttura IT. I firewall tradizionali filtrano il traffico di rete in entrata e in uscita, contribuendo a prevenire accessi non autorizzati e a bloccare traffico sospetto o dannoso, proteggendo così l'intera rete aziendale. I WAF, invece, sono progettati specificamente per proteggere le applicazioni web da minacce mirate, come attacchi che sfruttano vulnerabilità note.
- Una adeguata segmentazione di rete e l'utilizzo di zone demilitarizzate o DeMilitarized Zone (DMZ) controllate ed isolate (tra la rete interna ed esterna).
- Aggiornamenti periodici e installazione di patch critiche di sicurezza su tutta la piattaforma e la sua infrastruttura (sistemi operativi, database, software), inclusi antivirus, firewall e altre soluzioni di sicurezza.
- L'utilizzo di sistemi di protezione End Point (es. antivirus, antimalware) sui server.
- L'utilizzo di password complesse e uniche per tutti gli account e i servizi online; evitare di utilizzare password predefinite o facilmente indovinabili e considerare l'uso di gestori di password per gestire in modo sicuro le credenziali.
- L'utilizzo esteso dell'autenticazione a più fattori.
- L'utilizzo di strumenti di monitoraggio del traffico di rete per rilevare e rispondere prontamente a comportamenti anomali o attività sospette sulla rete.
- L'adozione di backup regolari completi e incrementali dei dati critici ed archiviazione degli stessi in un luogo sicuro al di fuori del sito di produzione.
- La limitazione dell'accesso da remoto solo ad utenti autorizzati e tramite l'utilizzo di una rete privata virtuale o Virtual Private Network (VPN)

per crittografare le connessioni e proteggere i dati.

- La limitazione dei privilegi amministrativi esclusivamente al personale autorizzato e solo per il tempo strettamente necessario allo svolgimento delle attività operative.

- La reimpostazione delle password amministrative di default immediatamente

dopo l'installazione dei sistemi, per evitare che credenziali predefinite vengano sfruttate da cybercriminali per ottenere accessi non autorizzati e compromettere le piattaforme aziendali.

- L'esecuzione di attività di vulnerability assessment e/o penetration test periodici per identificare prontamente e correggere eventuali falle di sicurezza sull'infrastruttura.

Implementando queste pratiche di sicurezza, è possibile ridurre significativamente il rischio di compromissione dei sistemi esposti su Internet e proteggere in modo efficace i dati e le risorse all'interno della rete aziendale.

Cosa comporta una limitazione non adeguata del numero di piattaforme che espongono servizi ad internet?

Una limitazione e protezione non adeguata del numero di piattaforme che espongono servizi ad internet aumenta il numero di possibili punti di ingresso per gli attaccanti, ampliando la superficie di esposizione ai rischi cyber da parte dell'organizzazione e incrementando la probabilità di violazioni della sicurezza e della privacy e l'interruzione del servizio.

Una limitazione non adeguata del numero di piattaforme esposte sul web comporta un aumento degli sforzi dell'organizzazione per la gestione ed il monitoraggio delle piattaforme e per la protezione della loro cybersicurezza.

13

Individua il punto di contatto, interno o esterno, che possa supportare l'organizzazione nella gestione degli attacchi informatici e degli incidenti di sicurezza.

AZIONI CHIAVE

1. Qualora la tua organizzazione sia dotata non solo di un responsabile per la cybersicurezza ma anche di un team specialistico interno a supporto, valuta di sviluppare un preciso modello di gestione degli incidenti cyber.

2. Favorisci programmi di consapevolezza e formazione specifica sulla gestione degli incidenti di sicurezza costruiti in base ai ruoli, alle procedure e agli strumenti adottati dall'organizzazione per affrontare tali situazioni.

CONTENUTI DI DETTAGLIO

Quando si tratta di sicurezza informatica, nessuna organizzazione è troppo piccola per essere immune a potenziali minacce e incidenti. Le grandi aziende non sono le uniche a essere prese di mira dagli attaccanti, al contrario, le organizzazioni di piccole e medie dimensioni possono essere considerate più vulnerabili a causa di risorse limitate e di misure di protezione meno strutturate, entrambe proporzionalmente legate alla dimensione e alla capacità di investimento dell'organizzazione.

Proprio per questo, è fondamentale, per ogni PMI, prepararsi a rispondere prontamente ed in maniera efficace agli incidenti e alle relative emergenze derivate dalle minacce di sicurezza. Un elemento chiave per una risposta tempestiva è una pronta identificazione dell'incidente di sicurezza.

Ci sono, infatti, alcuni indicatori a cui prestare attenzione, che possono aiutare l'organizzazione a riconoscere correttamente un incidente di sicurezza:

- **Impossibilità di accedere a dati, applicazioni o servizi di utilizzo quotidiano.**
- **Connessione di rete insolitamente lenta.**
- **Segnalazioni del software antimalware, di rilevazione di piattaforme infette.**

- **Log che rilevano un elevato numero di tentativi di accesso falliti.**
- **Rilevazione da parte del personale ICT di molteplici e-mail respinte con contenuto apparentemente sospetto o di flussi di rete insoliti.**

L'elenco riportato sopra è esemplificativo e non esaustivo di tutti gli indicatori che permettono l'individuazione di un incidente di sicurezza. Per questo **è fondamentale, con il supporto della dirigenza, sensibilizzare tutti gli utenti appartenenti all'organizzazione, in modo tale che siano in grado di rilevare prontamente l'incidente e adottare tutte le indicazioni aziendali fornite per bloccarlo**. È importante che ogni organizzazione comprenda le priorità funzionalmente alle proprie capacità ed agisca di conseguenza, considerando che gli attacchi cyber fanno sempre più leva sulla componente umana e sulla mancanza di consapevolezza, il vero anello debole della catena difensiva. Ogni organizzazione, dunque, con una pianificazione oculata e adeguata, può mettere in atto misure di sicurezza efficaci per difendersi dagli attacchi informatici.

Qualora l'organizzazione non dovesse avere le giuste risorse per sviluppare un preciso modello di gestione degli incidenti cyber, si raccomanda di avere chiari i punti di contatto del responsabile per la cybersicurezza e seguire le sue indicazioni (es. linee guida, procedure). Così si potrà garantire una risposta tempestiva ed efficace a eventuali minacce, anche, quando opportuno, con il supporto di fornitori dei servizi e delle forniture ICT.

Modello di gestione degli incidenti cyber

Nei casi in cui l'organizzazione sia dotata, non solo di un responsabile per la cybersicurezza, ma anche di un team specialistico interno a supporto, potrebbe avere le giuste risorse per sviluppare un preciso modello di gestione degli incidenti cyber. In tale circostanza, è fortemente consigliato intraprendere questa strada per rispondere prontamente alle minacce di sicurezza attraverso la definizione di un modello con ruoli, responsabilità e processi documentati che preveda almeno le seguenti 5 fasi:

Fase 1 - Pianificazione

In questa fase, rientrano le azioni per creare condizioni adeguate che possano prevenire e gestire gli incidenti in maniera appropriata:

- Stabilire i ruoli, le responsabilità, i processi e le procedure di gestione.
- Verificare le normative applicabili in materia di notifica degli incidenti.
- Diffondere e condividere il modello di gestione degli incidenti all'interno e all'esterno dell'organizzazione (es. fornitori).

Fase 2 - Identificazione dell'evento

Questa fase è la più complessa e onerosa, ed è quella in cui risulta fondamentale:

- Identificare e predisporre strumenti tecnici di rilevazione e valutazione delle minacce informatiche (es. Intrusion Detection Systems, Intrusion Prevention Systems, antivirus e antimalware).

Fase 3 - Gestione dell'incidente

In questa fase, in caso di violazione, è necessario effettuare le seguenti attività operative:

- **Rilevamento e analisi:** identificare i sistemi, le reti e le informazioni compromesse, valutando il potenziale impatto dell'incidente sull'organizzazione.
- **Contenimento:** elaborare e attuare un piano di contenimento efficace, basato sulle evidenze e le informazioni raccolte durante la fase di analisi.
- **Eliminazione, remediation e recovery:** rimuovere l'attaccante o la minaccia, attuare le misure correttive (remediation) necessarie e procedere con il ripristino dell'infrastruttura di rete e dei servizi di business coinvolti.

Fase 4 - Notifica dell'incidente

Ogni tipologia di incidente deve prevedere una specifica modalità di notifica. Nel dettaglio:

- In caso di violazione di dati personali, è necessario valutare l'impatto dell'incidente sui diritti e sulle libertà dei soggetti interessati, al fine di determinare l'eventuale obbligo di notifica al Garante per la protezione dei dati personali¹¹ e, se del caso, anche agli stessi soggetti interessati.
- È inoltre possibile segnalare volontariamente un evento attraverso il sito web dello CSIRT Italia¹². Tale segnalazione non equivale a una denuncia, querela o esposto, per i quali è necessario rivolgersi agli Organi di Polizia competenti o all'Autorità Giudiziaria.

Fase 5 - Miglioramento continuo

All'interno di un modello di gestione, il principio del miglioramento continuo riveste un ruolo essenziale. Di seguito sono riportati alcune azioni chiave per promuoverne l'attuazione concreta:

- Il modello di gestione degli incidenti deve essere aggiornato regolarmente, soprattutto in seguito a cambiamenti organizzativi, evoluzioni normative o sviluppi in ambito digitale e di cybersicurezza. Ogni aggiornamento apportato al piano deve essere comunicato e reso disponibile a tutte le parti interessate, sia interne sia esterne all'organizzazione. Per garantire l'efficacia e l'aggiornamento continuo del piano:
 - È fondamentale censire gli incidenti informatici e creare un repository degli attacchi noti, utile come base di conoscenza per riconoscere e affrontare in modo più rapido ed efficace eventuali incidenti simili in futuro.
 - Si raccomanda che le figure responsabili della gestione degli incidenti, anche con il supporto di fornitori o partner esterni, si incontrino periodicamente.
- L'obiettivo è migliorare la prevenzione e rafforzare la capacità di risposta, attraverso:

¹¹Data Breach - Violazioni di dati personali - Garante Privacy

¹²Segnalazione evento - CSIRT Italia

- > l'ottimizzazione degli strumenti di monitoraggio e controllo;
- > la revisione delle procedure operative;
- > il perfezionamento delle modalità di intervento in caso di incidente.
- E' essenziale programmare percorsi di formazione e di consapevolezza mirati alla gestione degli incidenti, in coerenza con la metodologia adottata e con l'approccio strutturato dell'organizzazione nella gestione di tali eventi.

Cosa comporta l'assenza di un piano d'azione efficace per la gestione degli incidenti?

La mancanza di un piano efficace per la gestione degli incidenti porta all'incapacità di gestire in modo adeguato e trasparente l'incidente, compromettendo, potenzialmente, la reputazione dell'organizzazione e la fiducia di clienti e fornitori.

La mancanza di figure preposte alla gestione degli incidenti (es. responsabile per la cybersicurezza) o di terze parti delegate a fornire un supporto in caso di emergenza, comporta un aumento delle tempistiche nella loro gestione e conseguentemente una maggiore probabile perdita, furto o violazione dell'integrità di dati riservati dell'azienda o dei clienti; se la risposta non risulta tempestiva e coordinata si consente ai potenziali attaccanti di continuare a sfruttare le vulnerabilità e causare danni.

La non adeguata gestione di un incidente di sicurezza comporta non solo l'interruzione della continuità operativa del business, compromettendo il servizio ai clienti e l'efficacia operativa ed il business dell'organizzazione, ma anche la violazione di leggi e normative con conseguenti sanzioni legali e danni economici.



14

Riserva un'adeguata attenzione all'analisi dei principali rischi cyber rilevanti per il tuo settore, al fine di migliorare la consapevolezza e rafforzare la postura di sicurezza dell'organizzazione.

AZIONI CHIAVE

1. Dedica una parte del tuo tempo a documentarti sui rischi e sulle minacce cyber rilevanti per il contesto della tua organizzazione.

2. Condividi con le dovute cautele e attraverso canali autorevoli le informazioni sulle minacce informatiche e sugli attacchi subiti; queste esperienze, messe a fattor comune, sono utili per innalzare il livello di sicurezza di

altre realtà del tuo settore, riducendo la vulnerabilità collettiva e combattendo il cybercrime in modo efficace e coordinato.

3. Consulta il sito del CSIRT Italia: è una delle principali fonti autorevoli da cui è possibile ottenere bollettini di sicurezza aggiornati e un quadro real-time sulle principali minacce monitorate a livello nazionale.

CONTENUTI DI DETTAGLIO

I cybercriminali utilizzano una varietà di tattiche sempre nuove e differenti; per questo è utile che le organizzazioni mettano a fattor comune le informazioni sulle minacce informatiche e sugli attacchi subiti e le utilizzino per innalzare sempre di più i loro presidi di sicurezza. Così facendo, l'esperienza del singolo permetterà di aiutare anche altre organizzazioni a comprendere meglio i rischi a cui vanno incontro e a identificare e rispondere prontamente alle minacce informatiche più comuni.

Il punto di riferimento a livello nazionale per la segnalazione di bollettini informativi su attività malevole e minacce emergenti è il CSIRT Italia, istituito presso l'Agenzia per la cybersicurezza nazionale (ACN).

Si raccomanda di consultare periodicamente i siti istituzionali e le fonti più autorevoli¹³ per essere sempre aggiornati sui rischi emergenti; consultarli è un investimento prezioso specialmente per le PMI, perché consente di comprendere meglio i rischi a cui queste organizzazioni sono esposte. È utile effettuare riflessioni su quali strategie avrebbero potuto essere adottate per mitigare l'impatto e ripristinare la continuità operativa, ipotizzando che la propria azienda fosse stata colpita dall'attacco in questione. Inoltre, è fondamentale valutare quali misure sono in essere

¹³ Dal CSIRT Italia non solo è possibile ottenere bollettini di sicurezza aggiornati e un quadro real-time sulle principali minacce monitorate a livello nazionale, ma anche inviare segnalazioni e informazioni su attacchi informatici rilevati o presunti.

per prevenire. È utile analizzare periodicamente attacchi informatici reali, ipotizzando il loro impatto sull'organizzazione, per valutare l'efficacia delle misure esistenti, identificare eventuali vulnerabilità non gestite e aggiornare le strategie di prevenzione e risposta.

Un'analisi e documentazione periodica consente di individuare tempestivamente minacce e vulnerabilità non gestite, riducendo in modo significativo la portata e l'impatto degli incidenti.

Cosa comporta il mancato aggiornamento e la mancata condivisione?

La mancanza di aggiornamento su possibili minacce e rischi cyber comporta un aumento della vulnerabilità collettiva, impedendo alle organizzazioni di imparare dagli incidenti altrui e di adottare misure preventive per evitare di cadere negli stessi attacchi.

La mancanza di aggiornamento sulle nuove minacce e vulnerabilità cyber emergenti espone l'organizzazione al rischio di attacco da parte dei cybercriminali proprio attraverso lo sfruttamento di vulnerabilità note e diffuse dai principali bollettini di sicurezza del settore.

Lista degli acronimi

ACN	agenzia per la cybersicurezza nazionale
CSIRT	computer security incident response team
DMZ	demilitarized zone
GDPR	general data protection regulation
IA	intelligenza artificiale
IaaS	infrastructure-as-a-service
IoT	internet of things
MFA	multi factor authentication
NIS	network and information security
NIST	national institute of standards and technology
PaaS	platform-as-a-service
PMI	piccole e medie imprese
PSNC	perimetro di sicurezza nazionale cibernetica
SaaS	software-as-a-service
SIEM	security information and event management
TLS	transport layer security
VPN	virtual private network
WAF	web application firewall